Trabalho ISO – Segurança da Informação (Família ISO/IEC 27000)

Aluno: Eduardo Lucas Lemes Januario

1. Problemas de Segurança da Informação identificados

a) Compartilhamento de senhas: impede a identificação de quem realizou cada ação (perda de rastreabilidade e de não repúdio) e amplia a exposição da credencial, facilitando acessos indevidos a códigos-fonte e documentos de clientes.

b) Ausência de procedimento formal de backup: uma falha de hardware, exclusão acidental ou ataque de ransomware pode causar perda permanente de dados, comprometendo a disponibilidade e a integridade das informações e a continuidade do negócio.

c) Contas de ex-funcionários não desativadas: pessoas sem vínculo com a empresa continuam podendo acessar o servidor, o que permite vazamento de código e dados de clientes, sabotagem ou uso da conta esquecida por atacantes externos.

2. Controles propostos (ABNT NBR ISO/IEC 27002:2022)

Problema	Controle sugerido	Justificativa
Senhas compartilhadas	**5.17 – Informações de autenticação** e **5.16 – Gestão de identidade** (apoiados por 8.5 – Autenticação segura)	Garante contas individuais e senhas pessoais e intransferíveis, com política de senhas fortes e, preferencialmente, MFA. Assim cada ação é atribuível a um único usuário.
Falta de backup	**8.13 – Backup das informações**	Define política de cópias periódicas (ex.: regra 3-2-1), com cópia fora do servidor principal e testes regulares de restauração, garantindo a recuperação dos dados.
Contas de ex-funcionários ativas	**5.18 – Direitos de acesso** e **6.5 – Responsabilidades após encerramento ou mudança da contratação**	Estabelece a revogação imediata dos acessos no desligamento (integrando RH e TI) e a revisão periódica das contas, eliminando acessos órfãos.

Adicionalmente, a ausência de análise de riscos deve ser tratada adotando o processo de gestão de riscos da ISO/IEC 27005, que orientará a priorização desses e de outros controles.

3. Análise de risco – Problema escolhido: ausência de backup

Elemento	Descrição
Ativo	Códigos-fonte dos sistemas e documentos de clientes armazenados no servidor interno (ativo de informação), além do próprio servidor (ativo de suporte).
Ameaça	Falha de hardware (ex.: pane no disco), ataque de ransomware, exclusão acidental por funcionário, ou incidentes físicos como incêndio e queda de energia.
Vulnerabilidade	Inexistência de procedimento formal de backup: os dados existem em uma única cópia, sem redundância nem teste de restauração.
Impacto	Perda total ou parcial dos dados; interrupção dos projetos e atrasos nas entregas; descumprimento de contratos; possíveis sanções pela LGPD em caso de perda de dados pessoais; danos financeiros e à reputação da empresa.
Avaliação	Probabilidade **média/alta** (falhas de disco e ransomware são comuns) × impacto **alto** = **risco alto**, que deve ser tratado com prioridade (opção de tratamento: modificar/mitigar o risco por meio do controle 8.13).

4. Diferença e complementaridade entre ISO/IEC 27002 e ISO/IEC 27005

A **ISO/IEC 27002** é um guia de **controles** de segurança: apresenta 93 controles, organizados em quatro temas (organizacionais, pessoas, físicos e tecnológicos), com orientações sobre o que implementar e como. Já a **ISO/IEC 27005** trata da **gestão de riscos**: orienta como identificar,

analisar, avaliar, tratar e monitorar os riscos de segurança da informação, ajudando a decidir onde e por que agir.

Elas se complementam: a 27005 é usada primeiro para levantar e priorizar os riscos da organização; em seguida, a 27002 fornece os controles adequados para tratá-los. No cenário, a análise de riscos (27005) mostraria que a falta de backup e os acessos indevidos são riscos altos, e a 27002 indicaria os controles 8.13, 5.17 e 5.18 para reduzi-los a um nível aceitável.

Referências

ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. **ABNT NBR ISO/IEC 27002:2022**: Segurança da informação, segurança cibernética e proteção à privacidade – Controles de segurança da informação. Rio de Janeiro: ABNT, 2022.

ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. **ABNT NBR ISO/IEC 27005:2023**: Segurança da informação, segurança cibernética e proteção à privacidade – Orientações para gestão de riscos de segurança da informação. Rio de Janeiro: ABNT, 2023.